



COURSE MANUAL

INFORMATION ASSURANCE AND SECURITY

This course provides students with the theoretical knowledge and practical skills in the implementation of Information Assurance and Security providing relevant solutions for security hardening and information protection through computer vulnerability assessment, secure coding, and computer security hardening techniques.



**BS - COMPUTER
SCIENCE
BS - INFORMATION
TECHNOLOGY**

Security and System Administration
Cluster

MODULE 4

RISK MANAGEMENT

Table of Contents

Contents

FOREWORD

CHAPTER 1

Lesson Topics

01

Overview of Risk Management

Information security risk management is a systematic process to identify, assess, and mitigate risks to an organization's information assets.

02

Quantitative Versus Qualitative Risk Management Practices

Quantitative risk control uses numerical data to calculate a risk's monetary impact or probability, while qualitative control uses subjective judgment to categorize risks as high, medium, or low.

03

Risk Management Framework

A risk management framework (RMF) in information security is a structured approach to identifying, assessing, mitigating, and continuously monitoring security risks.

Overview of Risk Management



Learning Outcomes:

- Explain the core components of risk management: identification, assessment, and control.
- Identify and classify information assets, threats, and vulnerabilities.
- Describe how risk levels are calculated and how risk control strategies are selected.

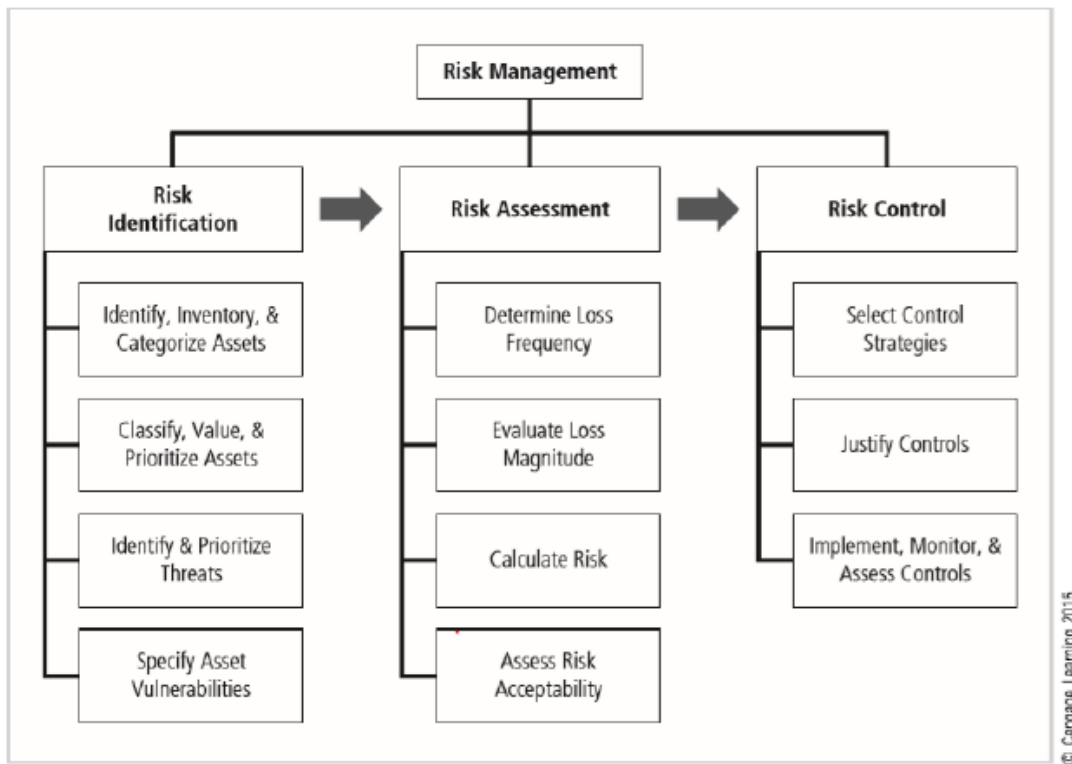


Understanding Risk Management

In the early days of information technology, corporations used IT systems mainly to gain a definitive advantage over the competition. Establishing a superior business model, method, or technique enabled an organization to provide a product or service that created a competitive advantage. These days, however, all competitors have reached a certain level of technological resilience. IT is now readily available to all organizations that make the investment, allowing them to react quickly to changes in the market. In this highly competitive environment, organizations cannot expect the implementation of new technologies to provide a competitive lead over others in the industry.

An Overview of Risk Management

Risk management involves three major undertakings: risk identification, risk assessment, and risk control. Initially, the organization must identify and understand the risk it faces, especially the risk to information assets. Once identified, risk must be assessed, measured, and evaluated. The key determination is whether the risk an organization faces exceeds its comfort level. If not, the organization is satisfied with the risk management process. Otherwise, the organization needs to do something to reduce risk to an acceptable level.



Components of risk management

© Cengage Learning 2015

Know Yourself

You must identify, examine, and understand the current information and systems in your organization. To protect information assets, which were defined earlier in this book as information and the systems that use, store, and transmit information, you must know what those assets are, where they are, how they add value to the organization, and the vulnerabilities to which they are susceptible. Once you know what you have, you can identify what you are already doing to protect it. Just because a control is in place does not necessarily mean that the asset is protected. Frequently, organizations implement control mechanisms but then neglect the necessary periodic review, revision, and maintenance. The policies, education and training programs, and technologies that protect information must be carefully maintained and administered to ensure that they remain effective.

Know the Enemy

Having identified your organization's assets and weaknesses, you move on to Sun Tzu's second step: Know the enemy. This means identifying, examining, and understanding the threats facing the organization. You must determine which threat aspects most directly affect the security of the organization and its information assets, and then use this information to create a list of threats, each one ranked according to the importance of the information assets that it threatens.

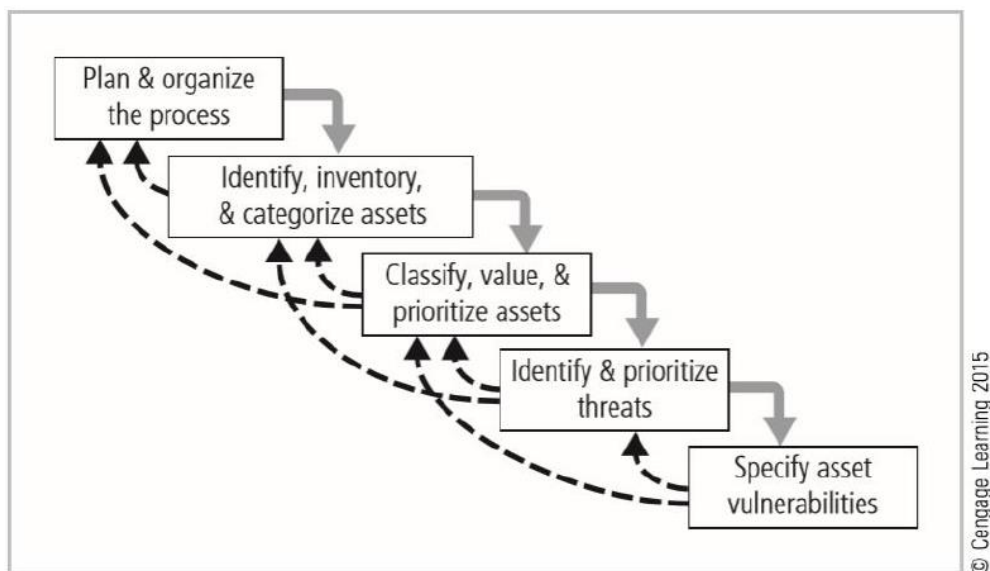
The Roles of the Communities of Interest

Each community of interest has a role to play in managing the risks that an organization encounters. Because members of the information security community best understand the threats and attacks that introduce risk into the organization, they often take a leadership role in addressing risk to information assets. Management and users, when properly trained and kept aware of the threats the organization faces, play a part in early detection and response. All communities of interest must work together to address all levels of risk, which range from disasters that can devastate the whole organization to the smallest employee mistakes. The three communities of interest are also responsible for the following:

- Evaluating the risk controls
- Determining which control options are cost effective for the organization
- Acquiring or installing the needed controls
- Ensuring that the controls remain effective

Understanding Risk Identification

A risk management strategy requires that information security professionals know their organizations' information assets—that is, how to identify, classify, and prioritize them. Once the organizational assets have been identified, a threat assessment process is used to identify and quantify the risks facing each asset.



Components of risk identification

Planning and Organizing the Process

As with any major undertaking in information security, the first step in risk identification is to follow your project management principles. You begin by organizing a team, which typically consists of representatives from all affected groups. Because risk can exist everywhere in the organization, representatives will come from every department and will include users, managers, IT groups, and information security groups. The process must then be planned, with periodic deliverables, reviews, and presentations to management. Once the project is ready to begin, the team can organize a meeting. Tasks are laid out, assignments are made, and timetables are discussed. Only then is the organization ready to begin the next step—identifying and categorizing assets.

Identifying, Inventorying, and Categorizing Assets

This iterative process begins with the identification and inventory of assets, including all elements of an organization's system, such as people, procedures, data and information, software, hardware, and networking. Then, you categorize the assets, adding details as you dig deeper into the analysis. The objective of this process is to establish the relative priority of assets to the success of the organization.

Traditional system components	SecSDLC components	Risk management system components
People	Employees	Trusted employees Other staff
	Nonemployees	People at trusted organizations Strangers and visitors
Procedures	Procedures	IT and business standard procedures IT and business-sensitive procedures
Data	Information	Transmission Processing Storage
Software	Software	Applications Operating systems Security components
Hardware	System devices and peripherals	Systems and peripherals Security devices
	Networking components	Intranet components Internet or DMZ components

Categorizing the Components of an Information System

© Cengage Learning 2015

People, Procedures, and Data Asset Identification

Identifying assets for human resources, documentation, and data is more difficult than identifying hardware and software assets. People with knowledge, experience, and judgment should be assigned the task. As assets for people, procedures, and data are identified, they should be recorded using a reliable data-handling process. Regardless of the record keeping mechanism you use, make sure it has the flexibility to allow specification of attributes for a particular type of asset. Some attributes are unique to a class of elements. When deciding which information assets to track, consider the following asset attributes:

- **People:** Position name, number, or ID (avoid using people's names and stick to identifying positions, roles, or functions); supervisor; security clearance level; special skills
- **Procedures:** Description; intended purpose; relationship to software, hardware, and networking elements; storage location for reference; storage location for update
- **Data:** Classification; owner, creator, and manager; size of data structure; data structure used (sequential or relational); online or offline; location; backup procedures employed.

Hardware, Software, and Network Asset Identification

Which attributes of hardware, software, and network assets should be tracked? It depends on the needs of the organization and its risk management efforts, as well as the preferences and needs of the information security and information technology communities. You may want to consider including the following asset attributes:

- **Name:** Use the most common device or program name. Organizations may have several names for the same product.
- **Ip address:** This can be a useful identifier for network devices and servers, but it does not usually apply to software.
- **Media access control (MAC) address:** MAC addresses are sometimes called electronic serial numbers or hardware addresses. As part of the TCP/IP standard, all network interface hardware devices have a unique number. The MAC address number is used by the network operating system to identify a specific network device.
- **Element type:** For hardware, you can develop a list of element types, such as servers, desktops, networking devices, or test equipment. The list can have any degree of detail you require. For software elements, you may develop a list of types that includes operating systems, custom applications by type (accounting, HR, or payroll, for example), packaged applications, and specialty applications, such as firewall programs.
- **Serial number:** For hardware devices, the serial number can uniquely identify a specific device. Some software vendors also assign a software serial number to each instance of the program licensed by the organization.
- **Manufacturer name:** Record the manufacturer of the device or software component.
- **Manufacturer's model number or part number:** Record the model or part number of the element
- **Software version, update revision, or FCO number:** Whenever possible, document the specific software or firmware revision number and, for hardware devices, the current field change order (FCO) number. An FCO is an authorization issued by an organization for the repair, modification, or update of a piece of equipment.
- **Physical location:** Note the element's physical location.
- **Logical location:** Note where the element can be found on the organization's network
- **Controlling entity:** Identify which organizational unit controls the element. Sometimes a remote location's onsite staff controls a networking device, and sometimes the central network team controls other devices of the same make and model.

Asset Inventory

Creating an inventory of information assets is a critical function of understanding what the organization is protecting. Unless the information assets are identified and inventoried, they cannot be effectively protected. The inventory process is critical in determining where information is located; most commonly it is in storage. While it may be impossible to completely control where information is located, policy and training programs can assist in informing employees where information should and should not be stored. The inventory process involves formalizing the identification process in some form of organizational tool. At this point in the process, simple spreadsheets and database tools can provide effective record keeping. The inventory information can be updated later with classification and valuation data. The inventory listing is usually available in a database, or it can be exported to a database for custom information about security assets. Once stored, the inventory listing must be kept current, often by means of a tool that periodically refreshes the data.

Asset Categorization

SecSDLC and risk management categorizations introduce several new subdivisions:

- People comprise employees and nonemployees. There are two subcategories of employees: those who hold trusted roles and have correspondingly greater authority and accountability, and other staff who have assignments without special privileges. Nonemployees include contractors and consultants, members of other trusted organizations, and strangers.
- Procedures essentially belong in one of two categories: procedures that do not expose knowledge a potential attacker might find useful, and sensitive procedures that could allow an adversary to gain an advantage or craft an attack against the organization's assets.
- Data components account for the management of information in all its states: transmission, processing, and storage.
- Software components are assigned to one of three categories: applications, operating systems, or security components. Security components can be applications or operating systems, but they are categorized as part of the information security control environment and must be protected more thoroughly than other system components.
- Hardware is assigned to one of two categories: the usual system devices and their peripherals, and devices that are part of information security control systems.

Most organizations further subdivide the categories. For example, the Hardware category can be subdivided into servers, networking devices (routers, hubs, switches), protection devices (firewalls, proxies), and cabling. Each of the other categories can be similarly subdivided as needed by the organization. You should also include a dimension to represent the sensitivity and security priority of the data and the devices that store, transmit, and process the data—that is, a data classification scheme. Any classification method must be specific enough to enable determination of priority levels, because the next step in risk assessment is to rank the components. It is also important that the categories be comprehensive and mutually exclusive. Comprehensive means that all information assets must fit in the list somewhere, and mutually exclusive means that an information asset should fit in only one category.

Data Classification and Management

Corporate and government organizations use a variety of classification schemes. Many corporations use a data classification scheme to help secure the confidentiality and integrity of information. A simplified information classification scheme would have three categories: confidential, internal, and external. The information classifications are as follows:

- **Confidential:** Used for the most sensitive corporate information that must be tightly controlled, even within the company. Access to information with this classification is strictly on a need-to-know basis or as required by the terms of a contract. Information with this classification may also be referred to as “sensitive” or “proprietary.”
- **Internal:** Used for all internal information that does not meet the criteria for the confidential category. Internal information is to be viewed only by corporate employees, authorized contractors, and other third parties.
- **External:** All information that has been approved by management for public release.

Security Clearances

Corresponding to the data classification scheme is the personnel security clearance structure. In organizations that require security clearances, all users of data must be assigned authorization levels that indicate what types of classified data they are authorized to view. This structure is usually accomplished by assigning each employee to a named role, such as data entry clerk, development programmer, information security analyst, or even CIO.

Most organizations have a set of roles and associated security clearances.

Management of Classified Data

Management of classified data includes its storage, distribution, transportation, and destruction. All information that is not unclassified or public must be clearly marked as such. The government also uses color-coordinated cover sheets to protect classified information from the casual observer, with Orange (Top Secret), Red (Secret), and Blue (Confidential) borders and fonts.

Information Asset Valuation

One of the toughest tasks of information security in general and risk management in particular is information asset valuation (The process of assigning financial value or worth to each information asset.). While most organizations have a general understanding of the relative worth of their information assets, it is much more difficult to place a specific financial value on an information asset. To assist in the process of assigning values to information assets for risk assessment purposes, you can pose several questions and collect your answers on a worksheet for later analysis. Before beginning the inventory process, the organization should determine which criteria can best establish the value of the information assets. Among the criteria to be considered are:

- Which information asset is most critical to the organization's success?
- Which information asset generates the most revenue?
- Which of these assets plays the biggest role in generating revenue or delivering services?
- Which information asset would be the most expensive to replace?
- Which information asset would be the most expensive to protect?
- Which information asset would most expose the company to liability or embarrassment if revealed?

Information Asset Prioritization

Once the inventory and value assessment are complete, you can prioritize each asset using a straightforward process known as weighted factor analysis. In this process, each information asset is assigned scores for a set of assigned critical factors. A score is assessed for each asset according to three assigned critical factors from 0.1 to 1.0, which is the range of values recommended in NIST SP 800-30, Risk Management for Information Technology Systems.

In addition, each critical factor is assigned a weight ranging from 1 to 100 to show the criterion's assigned importance for the organization.

Information asset	Criterion 1: Impact to revenue	Criterion 2: Impact to profitability	Criterion 3: Impact to public image	Weighted score
<i>Criteria weights must total 100</i>	30	40	30	
EDI Document Set 1—Logistics BOL to outsourcer (outbound)	0.8	0.9	0.5	75
EDI Document Set 2—Supplier orders (outbound)	0.8	0.9	0.6	78
EDI Document Set 2—Supplier fulfillment advice (inbound)	0.4	0.5	0.3	41
Customer order via SSL (inbound)	1.0	1.0	1.0	100
Customer service request via e-mail (inbound)	0.4	0.4	0.9	55

Example of a Weighted Factor Analysis Worksheet

Note: In the table, EDI stands for *electronic data interchange*, BOL stands for *bill of lading*, and SSL is *Secure Sockets Layer*.

© Cengage Learning 2015

Identifying and Prioritizing Threats

After an organization identifies and performs the preliminary classification of its information assets, the analysis phase next examines or evaluates threats to the organization (threat assessment). A wide variety of threats face an organization, its information, and its information systems. The realistic threats must be investigated further, while the unimportant threats are set aside. If you assume that every threat can and will attack every information asset, the project's scope quickly becomes so complex that it overwhelms your ability to plan.

Threat	Examples
Compromises to intellectual property	Piracy, copyright infringement
Deviations in quality of service	Internet service provider (ISP), power, or WAN service problems
Espionage or trespass	Unauthorized access and/or data collection
Forces of nature	Fire, floods, earthquakes, lightning
Human error or failure	Accidents, employee mistakes, failure to follow policy
Information extortion	Blackmail of information disclosure
Sabotage or vandalism	Destruction of systems or information
Software attacks	Viruses, worms, macros, denial of service
Technical hardware failures or errors	Equipment failure
Technical software failures or errors	Bugs, code problems, unknown loopholes
Technological obsolescence	Antiquated or outdated technologies
Theft	Illegal confiscation of property

Threats to Information Security⁸

Source: © 2003 ACM, Inc. Included with permission.

Each threat in Table must be examined to assess its potential to endanger the organization. This examination is known as a threat assessment. You can begin a threat assessment by answering a few basic questions, as follows:

- Which threats present danger to assets?
- Which threats represent the most danger to information?
- How much would it cost to recover from attack?
- Which threat requires greatest expenditure to prevent?

By answering the preceding questions, you establish a framework for discussing threat assessment. This list of questions may not cover everything that affects the information security threat assessment. If an organization has specific guidelines or policies, they should influence the process and require additional questions. This list can be easily expanded to include additional requirements.

Specifying Asset Vulnerabilities

Once you have identified the organization's information assets and documented some criteria for beginning to assess the threats it faces, you review each information asset for each relevant threat and create a list of vulnerabilities. Vulnerabilities are specific avenues that threat agents can exploit to attack an information asset. They are chinks in the armor—a flaw or weakness in an information asset, security procedure, design, or control that could be exploited accidentally or on purpose to breach security.

Threat	Possible vulnerabilities
Compromises to intellectual property	- Copyrighted works developed in-house and stored on intranet servers can be copied without permission unless the router is configured to limit access from outsiders. - Works copyrighted by others can be stolen; your organization is liable for that loss to the copyright holder.
Espionage or trespass	This information asset (router) may have little intrinsic value, but other assets protected by this device could be attacked if it does not perform correctly or is compromised.
Forces of nature	All information assets in the organization are subject to forces of nature unless suitable controls are provided.
Human error or failure	Employees or contractors may cause an outage if configuration errors are made.
Information extortion	If attackers bypass the router or compromise it and then enter your network, they may encrypt your data in place. They may not have stolen it, but unless you pay them to acquire the encryption key, the data is inert and no longer of value to you.
Deviations in quality of service	- Power system failures are always possible. Unless suitable electrical power conditioning is provided, failure is probable over time. - ISP connectivity failures can interrupt Internet bandwidth.
Sabotage or vandalism	The Internet protocol is vulnerable to denial of service. This device may be subject to defacement or cache poisoning.
Software attacks	The Internet protocol is vulnerable to denial of service. Outsider IP fingerprinting activities can reveal sensitive information unless suitable controls are implemented.
Technical hardware failures or errors	Hardware can fail and cause an outage.
Technical software failures or errors	Vendor-supplied routing software could fail and cause an outage.
Technological obsolescence	If this asset is not reviewed and periodically updated, it may fall too far behind its vendor support model to be kept in service.
Theft	Data has value and can be stolen. Routers are important network devices; their controls are critical layers in your defense in depth. When data is copied in place, you may not know it has been stolen.

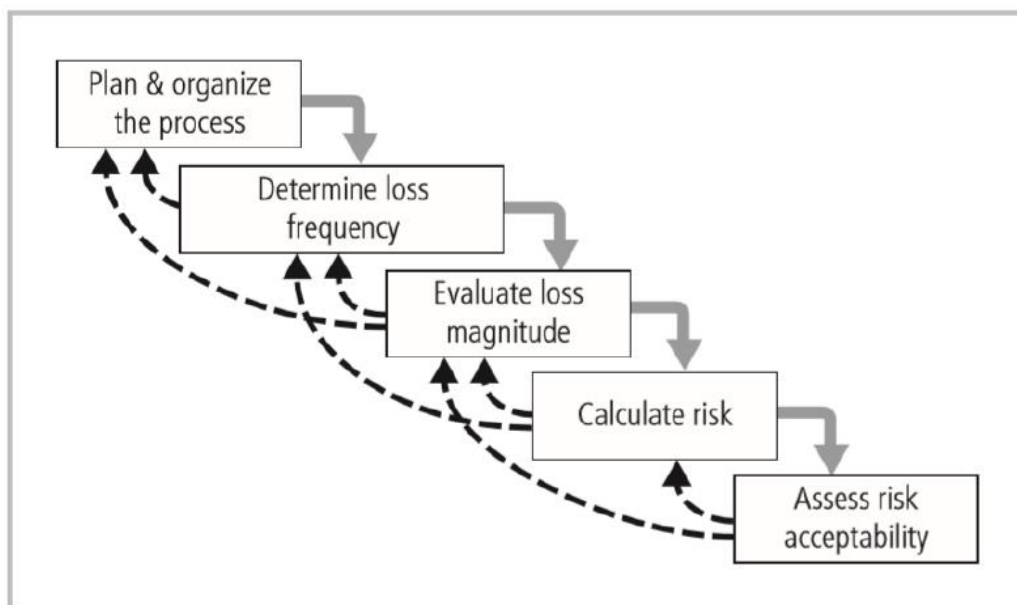
Vulnerability Assessment of a Hypothetical DMZ Router

© Cengage Learning 2015

Next, you examine how each possible or likely threat could be perpetrated, and list the organization's assets and their vulnerabilities. At this point in the risk identification phase, the focus is simply on identifying assets that have a vulnerability, not determining how vulnerable they are. The list is usually long and shows all the vulnerabilities of the information asset. Some threats manifest themselves in multiple ways, yielding multiple vulnerabilities. The process of listing vulnerabilities is somewhat subjective and depends on the experience and knowledge of the people creating the list. Therefore, the process works best when groups of people with diverse backgrounds within the organization work iteratively in a series of brainstorming sessions.

Understanding Risk Assessment

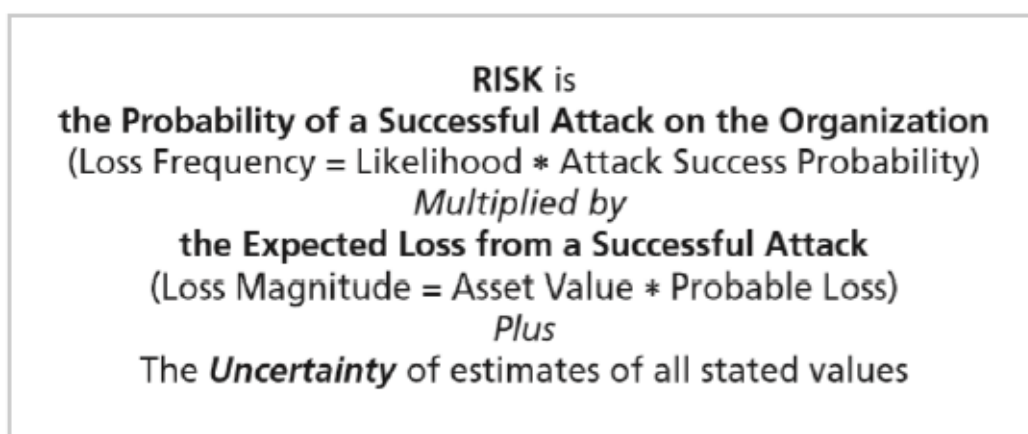
Now that you have identified the organization's information assets and its threats and vulnerabilities, you can evaluate the relative risk for each vulnerability. This process is called risk assessment. Risk assessment assigns a risk rating or score to each information asset. While this number does not mean anything in absolute terms, it is useful in gauging the relative risk to each vulnerable information asset and it facilitates the development of comparative ratings later in the risk control process.



© Cengage Learning 2015

Major stages of risk assessment

Planning and Organizing Risk Assessment



© Cengage Learning 2015

Factors of risk

The Figure above shows a simplified perspective of the factors that go into the risk-rating estimate for each vulnerability. The goal at this point is to create a method for evaluating the relative risk of each listed vulnerability. The risk model described in Figure is used to evaluate the risk for each information asset. The following sections itemize the factors that are used to calculate the relative risk for each vulnerability.

Determining the Loss Frequency

Loss frequency describes an assessment of the likelihood of an attack combined with its expected probability of success if it targets your organization (attack success probability). The resulting information will be coupled with an expected level of loss in evaluating risk. This calculation is also known as the annualized rate of occurrence, as you will see later in the chapter in the discussion of cost-benefit analysis.

Likelihood

In risk assessment, you assign a numeric value to the likelihood of an attack on your organization. For each threat, the organization must determine the expected likelihood of attack, which is typically converted to an annual value. Whenever possible, an organization should use external references for likelihood values that have been reviewed and adjusted for its specific circumstances. Many combinations of assets and vulnerabilities have references for determining the likelihood of an attack. For example:

- The likelihood of a fire has been estimated by actuaries for any type of structure.
- The likelihood that any given e-mail contains a virus or worm has been researched.
- The number of network attacks against an organization can be forecast based on its number of assigned network addresses.

Attack Success Probability

The second half of the loss frequency calculation is determining the probability of an attack's success if the organization becomes a target. The key component of this assessment is that the attack successfully compromises vulnerabilities in the organization's information asset. Another important part of the assessment is determining the organization's current level of protection, which further complicates the calculations and makes the "guestimates" that much more complex.

An attack can be successful only if it gets by the current level of protection; determining that level of protection requires fully understanding the various controls and safeguards in place. Creating estimates for the probability of a successful attack is very difficult. IT and information security technical staffs may tend to overestimate their level of preparedness, and managers may overstate the skills and qualifications of their staffs. In general, the accuracy of any estimates in this category is susceptible to a great deal of uncertainty.

Loss Event Frequency

Combining the likelihood and attack success probability results in an assessment of the loss frequency, also known as loss event frequency. To explain this assessment in other words, loss frequency is the probability that an organization will be the target of an attack, multiplied by the probability that the organization's information assets will be successfully compromised if attacked.

Evaluating Loss Magnitude

The next important step of risk assessment is to determine how much of an information asset could be lost in a successful attack. This quantity is known as the loss magnitude or asset exposure; its evaluation can be quantitative or qualitative. Organizations usually have some level of experience in creating best-case, worst-case, and most likely outcomes for various scenarios. The same types of calculations apply when determining loss magnitude. The event loss magnitude combines the value of an information asset with the percentage of that asset that would be lost in the event of a successful attack.

Calculating Risk

If an organization can determine loss frequency and loss magnitude for an asset, it can then calculate the risk to the asset. For the purpose of relative and simplistic risk determination, risk equals loss frequency times loss magnitude plus an element of uncertainty. A few examples will help explain risk calculations:

- Information asset A is an online e-commerce database. Industry reports indicate a 10 percent chance of an attack this year, based on an estimate of one attack every 10 years. The information security and IT departments report that if the organization is attacked, the attack has a 50 percent chance of success based on current asset vulnerabilities and protection mechanisms.

The asset is valued at a score of 50 on a scale of 0 to 100, and information security and IT staff expect that 100 percent of the asset would be lost or compromised by a successful attack. You estimate that the assumptions and data are 90 percent accurate.

- Information asset B is an internal personnel database behind a firewall. Industry reports indicate a 1 percent chance of an attack. The information security and IT departments report that if the organization is attacked, the attack has a 10 percent chance of success based on current asset vulnerabilities and protection mechanisms. The asset is valued at a score of 25 on a scale of 0 to 100, and information security and IT staff expect that 50 percent of the asset would be lost or compromised by a successful attack, because not all of the asset is stored in a single location. You estimate that the assumptions and data are 90 percent accurate.

Here are the risk ratings for the two vulnerabilities:

- Asset A's risk is $(10\% \times 50\%) \times (50 \times 100\%) + 10\%$, which is: $(5\% \times 50) + 10\% = 2.5 + 10\% = 2.75$
- Asset B's risk is $(1\% \times 10\%) \times (25 \times 50\%) + 10\%$, which is: $(0.1\% \times 12.5) + 10\% = 0.125 + 10\% = 0.1375$

Based on these calculations, the organization's asset A has a much higher level of risk than asset B.

Assessing Risk Acceptability

For each threat and its associated vulnerabilities that have residual risk, you must create a ranking of their relative risk levels, as illustrated in the previous sections. These rankings provide a simplistic approach to documenting residual risk—the left-over risk after the organization has done everything feasible to protect its assets. Next, the organization must compare the residual risk to its risk appetite—the amount of risk the organization is willing to tolerate.

Documenting the Results of Risk Assessment

By the end of the risk assessment process, you will probably have long lists of information assets and data about each of them. The goal so far has been to identify the information assets that have specific vulnerabilities, list them, and then rank them according to which need protection most.

In preparing the list, you collected and preserved a wealth of information about the assets, the threats they face, and the vulnerabilities they expose. You should also have collected some information about the controls that are already in place. The final summarized document is the ranked vulnerability risk worksheet, a sample of which is shown in Table. A review of this worksheet shows similarities to the approach used for the weighted factor analysis worksheet. The worksheet is organized as follows:

- **Asset:** List each vulnerable asset.
- **Asset relative value:** Show the results for the asset from the weighted factor analysis worksheet.
- **Vulnerability:** List each uncontrolled vulnerability. Some assets might be listed more than once.
- **Loss frequency:** Estimate the cumulative likelihood that the vulnerability will be successfully exploited by threat agents, as noted in the previous examples. In the table, the number ranges from 0 to 1.0 and corresponds to values of 0 percent to 100 percent.
- **Loss magnitude:** Calculate the estimated loss magnitude by multiplying the asset's relative value by the loss frequency. In this example, the calculation will yield a number from 0 to 100.

Asset	Asset relative value	Vulnerability	Loss frequency	Loss magnitude
Customer service request via e-mail (inbound)	55	E-mail disruption due to hardware failure	0.2	11
Customer order via SSL (inbound)	100	Lost orders due to Web server hardware failure	0.1	10
Customer order via SSL (inbound)	100	Lost orders due to Web server or ISP service failure	0.1	10
Customer service request via e-mail (inbound)	55	E-mail disruption due to SMTP mail relay attack	0.1	5.5
Customer service request via e-mail (inbound)	55	E-mail disruption due to ISP service failure	0.1	5.5
Customer order via SSL (inbound)	100	Lost orders due to Web server denial-of-service attack	0.025	2.5
Customer order via SSL (inbound)	100	Lost orders due to Web server software failure	0.01	1

Ranked Vulnerability Risk Worksheet

© Cengage Learning 2015

Understanding Risk Control

When an organization's management determines that risks from information security threats are creating a competitive disadvantage, it empowers the information technology and information security communities of interest to control the risks. Risk control involves three basic steps: selection of control strategies, justification of these strategies to upper management, and the implementation, monitoring, and ongoing assessment of the adopted controls.

Risk Control Strategies

Once the project team for information security development has created the ranked vulnerability risk worksheet, the team must choose a strategy for controlling each risk that results from these vulnerabilities. The five strategies are defense, transfer, mitigation, acceptance, and termination.

Risk control strategy	Categories used by NIST SP 800-30, Rev. 1	Categories used by ISACA and ISO/IEC 27001	Others
Defense	Research and Acknowledgement	Treat	Self-protection
Transfer	Risk Transference	Transfer	Risk transfer
Mitigation	Risk Limitation and Risk Planning	Tolerate (partial)	Self-insurance (partial)
Acceptance	Risk Assumption	Tolerate (partial)	Self-insurance (partial)
Termination	Risk Avoidance	Terminate	Avoidance

Summary of Risk Control Strategies

© Cengage Learning 2015

Defense

The defense control strategy attempts to prevent the exploitation of vulnerabilities. This strategy is the preferred approach to controlling risk. It is accomplished by countering threats, removing vulnerabilities from assets, limiting access to assets, and adding protective safeguards.

The defense strategy includes three common methods:

- Application of policy
- Education and training
- Application of technology

Organizations can mitigate risk to an asset by countering the threats it faces or by eliminating its exposure. Another defense strategy is to implement security controls and safeguards that deflect attacks on systems and therefore minimize the probability that an attack will be successful.

Transfer

The transfer control strategy attempts to shift risk to other assets, other processes, or other organizations. These controls can be accomplished by rethinking how services are offered, revising deployment models, outsourcing to other organizations, purchasing insurance, or implementing service contracts with providers. This principle should be considered whenever an organization begins to expand its operations, including information and systems management and even information security.

Mitigation

The mitigation control strategy attempts to reduce the impact of an attack rather than reduce the success of the attack itself. This approach requires the creation of three types of contingency plans: the incident response plan, the disaster recovery plan, and the business continuity plan. Each of these plans relies on the quality of the other plans and depends on the organization's ability to detect an attack and respond to it as quickly as possible. Mitigation begins with the early detection of an attack in progress and a quick, efficient, and effective response. The most common mitigation plans are contingency plans:

- **Incident response (IR) plan:** The actions an organization can and should take while an incident is in progress. The IR plan also enables the organization to take coordinated action that is either predefined and specific or ad hoc and reactive.
- **Disaster recovery (DR) plan:** The most common of the mitigation procedures, the DR plan includes all preparations for the recovery process, strategies to limit losses during a disaster, and detailed steps to follow in the aftermath.
- **Business continuity (BC) plan:** The most strategic and long-term plan of the three. The BC plan includes the steps necessary to ensure the continuation of the organization when the disaster's scope or scale exceeds the ability of the DR plan to restore operations, usually through relocation of critical business functions to an alternate location.

Acceptance

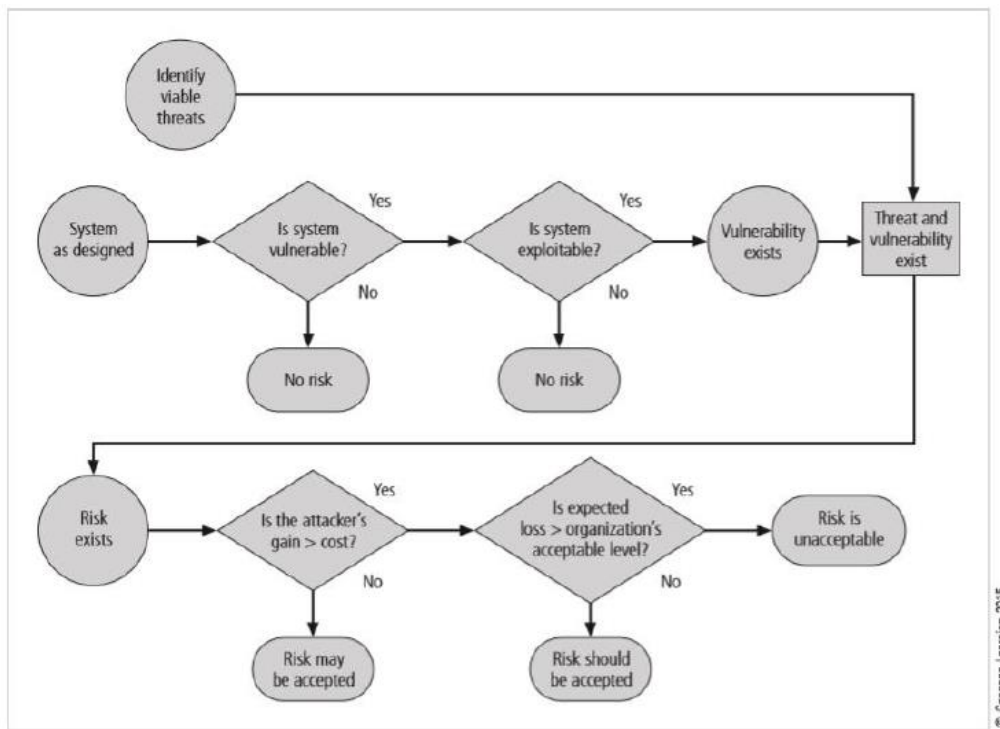
The acceptance control strategy is the choice to do nothing more to protect a vulnerability based on the current residual risk and the organization's risk appetite. This strategy may or may not be a conscious business decision. The only recognized valid use of this strategy occurs when the organization has done the following:

- Determined the level of risk
- Assessed the probability of attack
- Estimated the potential damage that could occur from attacks
- Performed a thorough cost-benefit analysis
- Evaluated controls using each appropriate type of feasibility
- Decided that the particular function, service, information, or asset did not justify the cost of protection

This strategy is based on the conclusion that the cost of protecting an asset does not justify the security expenditure.

Termination

The termination control strategy directs the organization to avoid business activities that introduce uncontrollable risks. For example, if an organization studies the risks of implementing business-to-consumer e-commerce operations and determines that the risks are not sufficiently offset by the potential benefits, the organization may seek an alternate mechanism to meet customer needs—perhaps developing new channels for product distribution or new partnership opportunities. By terminating the questionable activity, the organization reduces risk exposure. Risk control involves selecting one of the five risk control strategies for each vulnerability. The flowchart in Figure can guide you through the process of selecting one of the five strategies. The preceding risk control strategies are not designed to be implemented in isolation, but should be used to craft a portfolio approach to information security. Most organizations will choose a combination of strategies at this stage.



Risk handling decision points

© Cengage Learning 2015

Justifying Controls

Before implementing one of the five control strategies described in the previous section for a specific vulnerability, the organization must explore all consequences of the vulnerability to the information asset. To justify use of a control, the organization must determine the actual and perceived advantages of the control as opposed to its actual and perceived disadvantages.

When justifying the acquisition of new controls or safeguards, the management of most organizations would expect to see a carefully developed business case that provides insight into the needs, costs, and values of these acquisitions.

Thus, information security staff must prepare effective business justifications for information security expenditures, illustrating the costs, benefits, and other reasons that upper management should make the additional investments. Some investments involve time and effort, but virtually all boil down to some form of economic feasibility, which organizations must consider when implementing information security controls and safeguards. Although several alternatives may exist for solving a problem, they may not have the same economic feasibility. Most organizations can spend only a certain amount of time and money on information security, and those amounts differ from organization to organization and even from manager to manager.

Organizations are urged to evaluate the worth of the information assets to be protected and the loss in value if those assets are compromised by an exploited vulnerability. In short, organizations must gauge the cost of protecting an asset against the value of that asset. This formal decision making process is called a **cost-benefit analysis (CBA)** or an economic feasibility study.

The amount of the benefit is usually determined by valuing the information asset(s) exposed by the vulnerability, determining how much of that value is at risk, and determining how much risk exists for the asset. The valuation of assets involves estimating real and perceived costs associated with design, development, installation, maintenance, protection, recovery, and defense against loss and litigation. These estimates are calculated for every set of information-bearing systems or information assets. Some component costs are easy to determine, such as the cost to replace a network switch or the hardware needed for a specific class of server.

Asset valuation techniques are discussed in more detail earlier in this chapter. Once an organization has estimated the worth of various assets, it can begin to examine the potential loss that could occur from an exploited vulnerability or threat occurrence. This process results in the estimate of potential loss per risk. Several questions must be asked as part of this process:

- What damage could occur, and what financial impact would it have?
- What would it cost to recover from the attack, in addition to the financial impact of damage?
- What is the single loss expectancy (SLE) for each risk? Note that $SLE = \text{exposure factor (EF)} \times \text{asset value (AV)}$.

In most cases, the probability of a threat occurring is shown in a loosely derived table that indicates the probability of an attack from each threat type within a given time frame (for example, once every 10 years). This value is commonly referred to as the annualized rate of occurrence (ARO). To standardize calculations, you convert the rate to a yearly (annualized) value. This value is expressed as the probability of a threat occurrence.

Once each asset's worth is known, the next step is to ascertain how much loss is expected from a single expected attack and how often these attacks occur. When those values are established, an equation can be completed to determine the overall lost potential per risk. This value is usually determined through the annualized loss expectancy (ALE), which is calculated from the ARO and SLE: $ALE = SLE \times ARO$

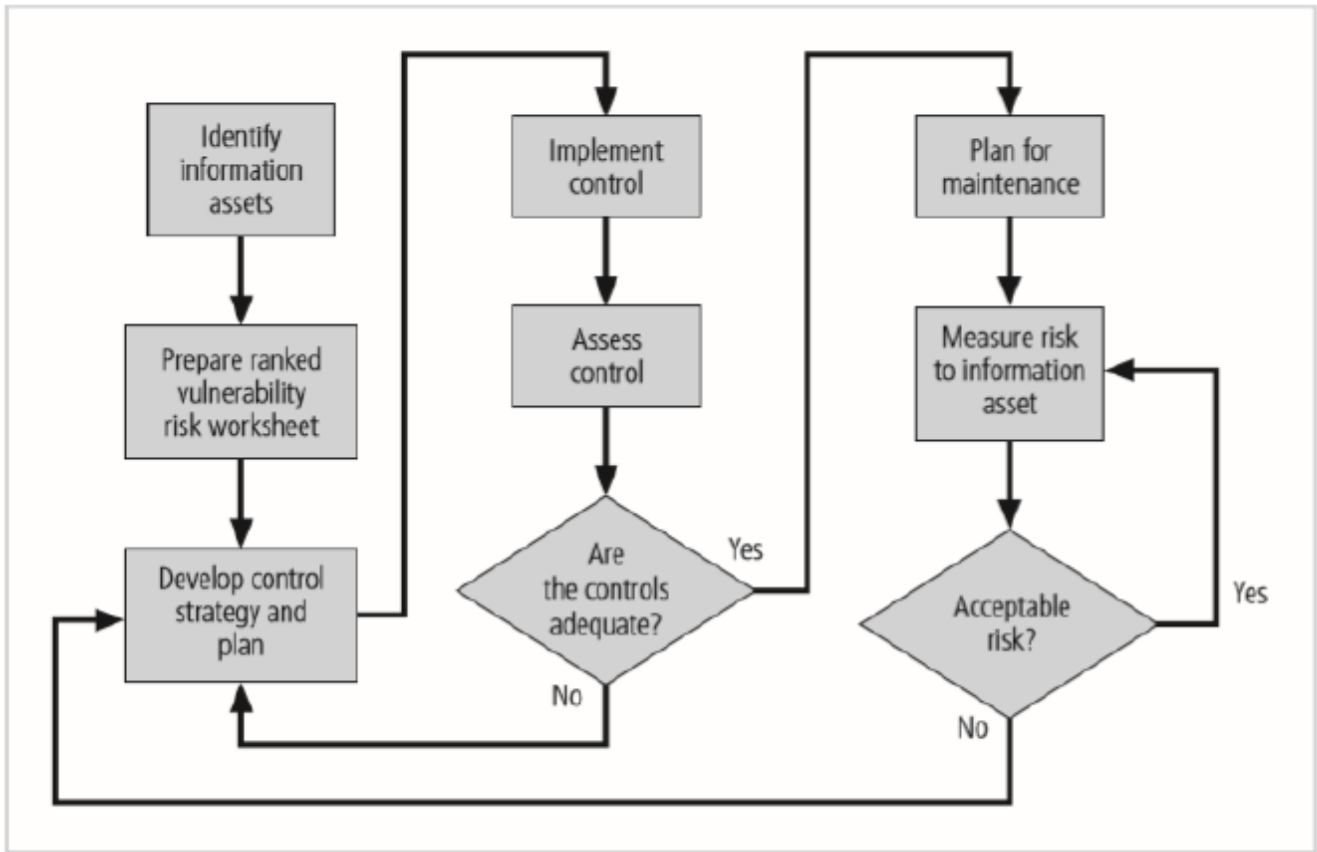
The Cost-Benefit Analysis (CBA) Formula

In its simplest definition, CBA (or economic feasibility) determines whether a particular control is worth its cost. CBAs may be calculated before a control or safeguard is implemented to determine if the control is worth implementing. CBAs can also be calculated after controls have been functioning for a while. Observation over time adds precision to evaluating the benefits of the safeguard and determining whether it is functioning as intended. While many techniques exist, the CBA is most easily calculated using the ALE from earlier assessments before implementation of the proposed control, which is known as ALE(prior). Subtract the revised ALE, which is estimated based on the control being in place; this revised value is known as ALE(post). Complete the calculation by subtracting the annualized cost of a safeguard (ACS).

Formula: $CBA = ALE(prior) - ALE(post) - ACS$

Implementation, Monitoring, and Assessment of Risk Controls

The selection of a control strategy is not the end of a process. The strategy and its accompanying controls must be implemented and then monitored on an ongoing basis to determine their effectiveness and to accurately calculate the estimated residual risk. Once controls are implemented, it is crucial to continually examine their benefits to determine when they must be upgraded, supplemented, or replaced.



Risk control cycle

Quantitative Versus Qualitative Risk Management Practices



Learning Outcomes:

- Differentiate qualitative and quantitative risk analysis.
- Apply DREAD and EF/SLE/ARO/ALE models in evaluating risks.
- Explain the roles of benchmarking, best practices, and baselining in risk analysis.



Understanding Quantitative Versus Qualitative Risk Management

The steps described in the previous section were performed using actual values or estimates. This approach is known as a **quantitative assessment** (An asset valuation approach that attempts to assign absolute numerical measures.). However, an organization might decide that it cannot apply specific numbers to these values. Fortunately, it can perform these steps using an evaluation process called **qualitative assessment** (An asset valuation approach that uses categorical or non-numeric values rather than absolute numerical measures.), which does not use numerical measures.

When to Perform a Qualitative and Quantitative Risk Analysis

Qualitative risk analysis should be performed when there is a change in the perception of a risk and when a new risk has been identified. As a general rule, project managers should always perform qualitative risk analysis at the beginning of every project.



Quantitative risk analysis should be performed when there is a large amount of data on the risk and its impact and when qualitative risk analysis needs to be validated. Since performing quantitative risk analysis can be difficult and time-consuming, it is not recommended by most project managers unless the safety of the project relies on precise estimations of risk.

Qualitative Risk Analysis

The DREAD model quantitatively assesses the severity of a cyberthreat using a scaled rating system that assigns numerical values to risk categories (Meier et al., 2003).

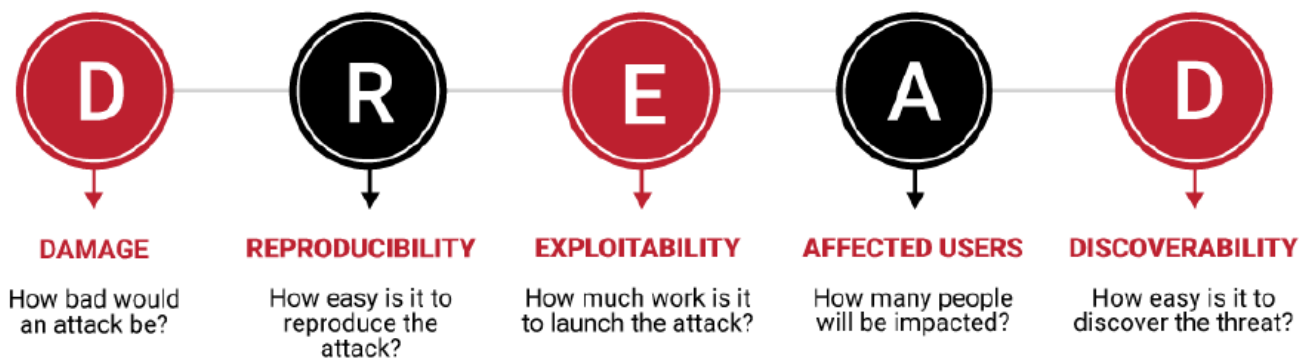


Image Retrieved from <https://wildcardcorp.com/image-repository/dread.png>

Rating		High (3)	Medium (2)			Low (1)	
D	Damage potential	The attacker can subvert the security system	Leaking sensitive information			Leaking trivial information	
R	Reproducibility	The attack can be reproduced every time and does not require a timing window.	The attack can be reproduced, but only with a timing window and a particular race situation.			The attack is very difficult to reproduce, even with knowledge of the security hole.	
E	Exploitability	A novice programmer could make the attack in a short time.	A skilled programmer could make the attack, then repeat the steps.			The attack requires an extremely skilled person and in-depth knowledge every time to exploit.	
A	Affected users	All users, default configuration, key customers	Some users, non-default configuration			Very small percentage of users, obscure feature; affects anonymous users	
D	Discoverability	The vulnerability is found in the most commonly used feature and is very noticeable.	The vulnerability is in a seldom-used part of the product, and only a few users should come across it.			The bug is obscure, and it is unlikely that users will work out damage potential.	

No	Threat	D	R	E	A	D	Total	Rating
1	Attacker obtains authentication credentials by monitoring the network.	3	3	2	2	2	12	High
2	SQL commands injected into application.	3	3	3	3	2	14	High

Image Retrieved from <https://www.slideshare.net/chinwhei/7-steps-to-threat-modeling>

The rating values represent severity and are expressed as numbers (3-high, 2-medium, 1-low). The risk rating is obtained by adding rating values for all items and comparing the results with the following table:

Risk rating Result

- High 12-15
- Medium 8-11
- Low 5-7

Quantitative Risk Analysis using EF, SLE, ARO and ALE

Quantitative analysis is about assigning monetary values to risk components. The key variables and equations used for conducting a quantitative risk analysis are shown below.

	Formula	Description
Asset value (AV)	AV	Value of the asset
Exposure factor (EF)	EF	Percentage of asset value lost
Single-loss expectancy (SLE)	$AV \times EF$	Cost of one loss
Annual rate of occurrence (ARO)	ARO	Number of losses per year
Annualized loss expectancy (ALE)	$SLE \times ARO$	Cost of losses per year

- **Exposure Factor (EF):** Percentage of asset loss caused by identified threat. It ranges from 0% to 100%.
- **Single Loss Expectancy (SLE):** Asset Value $\times$ Exposure factor.
- **Annualized Rate of Occurrence (ARO):** Estimated frequency a threat will occur within a year and is characterized on an annual basis. A threat occurring one time every 10 years has an ARO of 0.1. A threat occurring 10 times in a year has an ARO of 10.
- **Annualized Loss Expectancy (ALE):** Single Loss Expectancy $\times$ Annualized Rate of Occurrence.

EXAMPLE

The concept can be summarized by analyzing the example of a stolen corporate laptop to understand better how it works. Let's first describe the threat, vulnerability and risk:

Threat: Stolen corporate laptop

Vulnerability: Backup rarely performed

Risk: Loss of data

Asset: Data (\$100,000)

Single loss expectancy (SLE). It contains information about the potential loss when a threat occurs. $SLE = AV \times EF$, where EF is exposure factor. Exposure factor describes the loss that will happen to the asset because of the threat. SLE is \$30,000 in our example when EF is estimated to be 0.3.

Annualized Rate of Occurrence (ARO) is described as an estimated frequency of the threat occurring in one year. ARO is used to calculate ALE (annualized loss expectancy). ALE is calculated as follows: $ALE = SLE \times ARO$. ALE is \$15,000 ($\$30,000 \times 0.5$), when ARO is estimated to be 0.5 (once in two years).

As we can see, the risk is about the impact of the vulnerability on the business and the probability of the vulnerability to be exploited.

Benchmarking and Best Practices

Instead of determining the financial value of information and then implementing security as an acceptable percentage of that value, an organization could take a different approach to risk management and look to peer organizations for benchmarks. **Benchmarking** involves seeking out and studying practices used in other organizations that produce results you would like to duplicate in your organization. An organization typically benchmarks itself against other institutions by selecting a measure upon which to base the comparison. The organization then measures the difference between the way it conducts business and the way the other organizations do business. When benchmarking, an organization typically uses one of two types of measures to compare practices: metrics-based measures or process-based measures.

Metrics-based measures are based on numerical standards, such as:

- Numbers of successful attacks
- Staff-hours spent on systems protection
- Dollars spent on protection
- Numbers of security personnel
- Estimated value in dollars of the information lost in successful attacks
- Loss in productivity hours associated with successful attacks

An organization uses numerical standards like these to rank itself against competing organizations with a similar size or market and then determine how it measures up to the competitors. Performance gaps provide insight into areas that an organization should work on to improve its security postures and defenses.

The other measures commonly used in benchmarking are process-based measures, which are generally less focused on numbers and are more strategic than metrics-based measures. For each area the organization is interested in benchmarking, process-based measures enable it to examine the activities it performs in pursuit of its goal, rather than the specifics of how the goals are attained. The primary focus is the method the organization uses to accomplish a particular process, rather than the outcome. In information security, two categories of benchmarks are used: standards of due care and due diligence, and best practices.

Security efforts that seek to provide a superior level of performance in the protection of information are referred to as best business practices, or simply best practices or recommended practices.

Applying Best Practices

The preceding sections presented several sources to consider when applying standards to your organization. You can study documented best practice processes or procedures that have been shown to be effective or that have been recommended by a trusted person or organization, and then evaluate how they apply to your organization. When considering best practices for adoption, think about the following:

- Does your organization resemble the identified target organization that is considering the best practice? Is your organization in a similar industry as the target? A strategy that works well in manufacturing organizations often has little bearing in a nonprofit organization. Does your organization face similar challenges as the target? If your organization does not have a functioning information security program, a best-practice target that assumes you do is not useful. Is your organization's structure similar to the target's? Obviously, a best practice proposed for a home office setting is not appropriate for a multinational company.
- Can your organization expend resources similar to those identified with the best practice? If your approach is significantly limited by the organization's resources, it is not useful to submit a best-practice proposal that assumes unlimited funding.
- Is your organization in a similar threat environment as the one proposed in the best practice? A best practice from months or even weeks ago may not be appropriate for the current threat environment.

Problems With the Application of Benchmarking and Best Practices

The biggest problem with benchmarking and best practices in information security is that organizations don't talk to each other. A successful attack is viewed as an organizational failure, not as a lesson. Because these valuable lessons are not recorded, disseminated, and evaluated, the entire industry suffers. However, more and more security administrators are joining professional associations and societies (such as the Information Systems Security Association), sharing stories, and publishing the lessons learned. Security administrators often submit sanitized accounts of attacks to security journals after removing details that could identify the targeted organization. Still, most organizations refuse to acknowledge, much less publicize, the occurrence of successful attacks. Another problem with benchmarking is that no two organizations are identical. Even if two organizations are producing goods or services in the same market, their sizes, compositions, management philosophies, organizational cultures, technological infrastructures, and security budgets may differ dramatically.

Thus, even if these organizations did exchange specific information, it may not apply in other contexts. What organizations seek most are lessons and examples rather than specific technologies they should adopt, because they know that security is a managerial problem, not a technical one. If security were a technical problem, implementing a certain technology could solve the problem regardless of industry or organizational composition. In fact, however, the number and types of variables that affect an organization's security can differ radically among businesses.

A third problem is that best practices are a moving target. What worked well two years ago may be completely worthless against today's threats. Security practices must keep abreast of new threats in addition to the methods, techniques, policies, guidelines, educational and training approaches, and technologies used to combat those threats.

A final issue to consider is that simply researching information security benchmarks doesn't necessarily prepare a practitioner for what to do next. It is said that those who cannot remember the past are condemned to repeat it. In security, those who do not prepare for common attacks see them occur again and again. However, preparing for past threats does not safeguard against new

Baselining

An activity related to benchmarking is baselining (The comparison of past security activities and events against the organization's current performance.). In information security, baselining can provide the foundation for internal benchmarking. The information gathered for an organization's first risk assessment becomes the baseline for future comparisons. Therefore, it is important for the initial baseline to be accurate.

Other Feasibility Studies

An organization's readiness for any proposed set of controls can be determined using several other qualitative approaches, including operational, technical, and political feasibility analyses. The methods for these feasibility evaluations are discussed in the following sections.

- **Organizational Feasibility** Organizational feasibility analysis examines how the proposed control must contribute to the organization's strategic objectives. Above and beyond their impact on the bottom line, the organization must determine how the proposed alternatives contribute to its business objectives. Does the implementation align with the strategic planning for the information systems, or does it require deviation from the planned expansion and management of the current systems?
- **Operational Feasibility** Operational feasibility analysis addresses several key areas that are not covered by the other feasibility measures. Operational feasibility, also known as behavioral feasibility, measures employees' acceptance of proposed changes. A fundamental requirement of systems development is user buy-in. If users do not accept a new technology, policy, or program, it will fail. One of the most common methods for obtaining user acceptance and support is to encourage user involvement. To promote user involvement, an organization can take three simple steps: communicate, educate, and involve.
- **Technical Feasibility** In addition to the economic costs and benefits of proposed controls, the project team must also consider the technical feasibility of their design, implementation, and management. Some safeguards, especially technology-based safeguards, are extremely difficult to implement, configure, and manage.

Does the organization have the hardware and software necessary to support a new firewall system? If not, can it be obtained? Technical feasibility also examines whether the organization has the expertise to manage the new technology. These issues must be examined in detail before a new set of controls is acquired. Many organizations rush to acquire new safeguards without completely examining the associated requirements.

- **Political Feasibility** For some organizations, the most important feasibility evaluated may be political feasibility. Politics has been defined as “the art of the possible”. The information security controls that limit an organization’s actions or behaviors must fit within the realm of the possible before they can be effectively implemented, and that realm includes the availability of staff resources. In some cases, resources are provided directly to the information security community under a budget apportionment model. The management and professionals involved in information security then allocate resources to activities and projects using processes of their own design.

Risk Management Framework



Learning Outcomes:

- Describe what an IT security framework is and why it's used.
- Identify major frameworks (ISO 27000, NIST, COBIT, CIS, HITRUST, etc.).
- Explain how organizations choose and apply security frameworks.



Understanding Risk Management Framework

An IT security framework is a series of documented processes that define policies and procedures around the implementation and ongoing management of information security controls. These frameworks are a blueprint for managing risk and reducing vulnerabilities. Information security professionals use frameworks to define and prioritize the tasks required to manage enterprise security. Frameworks are also used to help prepare for compliance and other IT audits. Therefore, the framework must support specific requirements defined in the standard or regulation.



How to choose an IT security framework?

The choice to use a particular IT security framework can be driven by multiple factors. The type of industry or compliance requirements could be deciding factors. Publicly traded companies, for example, may wish to use COBIT to comply with Sarbanes-Oxley, while the healthcare sector may consider HITRUST. The ISO 27000 Series of information security frameworks, on the other hand, is applicable in public and private sectors.

While ISO standards are often time-consuming to implement, they are helpful when an organization needs to demonstrate its information security capabilities via ISO 27000 certification. While NIST Special Publication (SP) 800-53 is the standard required by U.S. federal agencies, it can be used by any organization to build a technology-specific information security plan.

These frameworks help security professionals organize and manage an information security program. The only bad choice among these frameworks is not choosing any of them.

Examples of IT security standards and frameworks

The **ISO 27000 Series** was developed by the International Organization for Standardization. It is a flexible information security framework that can be applied to all types and sizes of organizations.

Compliance with ISO 27000 Series standards is established through audit and certification processes, typically provided by third-party organizations approved by ISO and other accredited agencies.

The ISO 27000 Series has 60 standards covering a broad spectrum of information security issues, for example:

- ISO 27018 addresses cloud computing.
- ISO 27031 provides guidance on IT disaster recovery programs and related activities.
- ISO 27037 addresses the collection and protection of digital evidence.
- ISO 27040 addresses storage security.
- ISO 27799 defines information security in healthcare, which is useful for companies that require HIPAA compliance.

NIST has developed an extensive library of IT standards, many of which focus on information security. First published in 1990, the NIST SP 800 Series addresses virtually every aspect of information security, with an increasing focus on cloud security.

NIST SP 800-53 is the information security benchmark for U.S. government agencies and is widely used in the private sector. SP 800-53 has helped spur the development of information security frameworks, including the NIST Cybersecurity Framework (CSF).

NIST SP 800-171 has gained popularity due to requirements set by the U.S. Department of Defense regarding contractor compliance with security frameworks. Government contractors are a frequent target for cyber attacks due to their proximity to federal information systems. Government manufacturers and subcontractors must have an IT security framework to bid on federal and state business opportunities.

The **NIST Framework for Improving Critical Infrastructure Cybersecurity**, or NIST CSF, was developed under Executive Order 13636, released in February 2013. It was developed to address U.S. critical infrastructure, including energy production, water supplies, food supplies, communications, healthcare delivery and transportation. These industries must maintain a high level of preparedness, as they have all been targeted by nation-state actors due to their importance.

The **NIST SP 1800** Series is a set of guides that complement the NIST SP 800 Series of standards and frameworks. The SP 1800 Series of publications offers information on how to implement and apply standards-based cybersecurity technologies in real-world applications.

COBIT was developed in the mid-1990s by ISACA, an independent organization of IT governance professionals. ISACA offers the well-known Certified Information Systems Auditor and Certified Information Security Manager certifications. COBIT originally focused on reducing IT risks. COBIT 5, released in 2012, included new technology and business trends to help organizations balance IT and business goals. The current version is COBIT 2019. It's the most used framework to achieve Sarbanes-Oxley compliance. Numerous publications and professional certifications address COBIT requirements.

The **Center for Internet Security (CIS) Critical Security Controls**, Version 8 -- formerly the SANS Top 20 -- lists technical security and operational controls that can be applied to any environment. It does not address risk analysis or risk management like NIST CSF; rather, it is solely focused on reducing risk and increasing resilience for technical infrastructures.

The **HITRUST Common Security Framework** includes risk analysis and risk management frameworks, along with operational requirements. The framework has 14 different control categories and can be applied to almost any organization, including healthcare.

GDPR is a framework of security requirements that global organizations must implement to protect the security and privacy of EU citizens' personal information. GDPR requirements include controls for restricting unauthorized access to stored data and access control measures, such as least privilege, role-based access and multifactor authentication.

COSO is a joint initiative of five professional organizations. Its 2013 framework covers internal controls, and its 2017 framework covers risk management.

LESSON SUMMARY

Risk management examines and documents the information technology security being used in an organization. Risk management helps an organization identify vulnerabilities in its information systems and take carefully reasoned steps to assure the confidentiality, integrity, and availability of all components in those systems.

A key component of a risk management strategy is the identification, classification, and prioritization of the organization's information assets.

The human resources, documentation, and data information assets of an organization are more difficult to identify and document than tangible assets, such as hardware and software.

After performing a preliminary classification of information assets, the organization should examine the threats it faces. There are 12 categories of threats to information security.

Qualitative risk analysis is the process of rating or scoring risk based on a person's perception of the severity and likelihood of its consequences.

Quantitative risk analysis is the process of calculating risk based on data gathered. The goal of quantitative risk analysis is to further specify how much will the impact of the risk cost the business. This is achieved by using what's already known to predict or estimate an outcome.

Benchmarking is an alternative method to economic feasibility analysis that seeks out and studies practices used in other organizations to produce desired results in one's own organization.

Baselining, the comparison of past security activities and events against the organization's current performance.

An IT security framework is a series of documented processes that define policies and procedures around the implementation and ongoing management of information security controls. These frameworks are a blueprint for managing risk and reducing vulnerabilities.

KEY TERMS

- Risk Identification
- Risk Assessment
- Risk Control
- Risk Management
- Data Classification Scheme
- Security Clearance
- Asset Valuation
- Threat Assessment
- Likelihood
- Loss Frequency
- Attack Success Probability
- Loss Magnitude
- Asset Exposure
- Defense Control Strategy
- Transfer Control Strategy
- Mitigation Control Strategy
- Acceptance Control Strategy
- Termination Control Strategy
- Qualitative Assessment
- Quantitative Assessment
- Benchmarking
- Best Business Practices
- Baselining
- Behavioral Feasibility
- Operational Feasibility
- Organizational Feasibility
- Political Feasibility
- Technical Feasibility

REFERENCES



Electronic Books

- Whiteman, et.al. "Principles of Information Security", 3rd Edition

Online Sources

- Meier, J. D., Mackman, A., Dunner, M., Vasireddy, S., Escamilla, R., & Murukan, A. (2003). Improving web application security: Threats and countermeasures. Microsoft Corporation. [https://docs.microsoft.com/en-us/previousversions/msp-n-p/ff649874\(v=pandp.10\)](https://docs.microsoft.com/en-us/previousversions/msp-n-p/ff649874(v=pandp.10))
- SafetyCulture 2022, "Qualitative and Quantitative Risk Analysis", <https://safetyculture.com/topics/qualitative-andquantitative-risk-analysis/>
- InfoSec 2018, "How to perform qualitative & quantitative security risk analysis", <https://resources.infosecinstitute.com/topic/perform-qualitative-quantitative-security-risk-analysis/>
- Paul Kirvan & Joseph Granneman, "Top 10 IT security frameworks and standards explained", <https://www.techtarget.com/searchsecurity/tip/IT-security-frameworks-and-standards-Choosingthe-right-one>